

Relatório de Auditoria de Segurança

Andrade Serviços de Tecnologia — Plataforma Web Corporativa & Portfólio de IA

ORGANIZAÇÃO / CLIENTE

Andrade Serviços de Tecnologia

DOMÍNIO OFICIAL

tecnologiandrade.com.br

ESCOPO AUDITADO

Código Fonte (TypeScript/React), Headers HTTP, Configs de Deploy & Git

DATA DA AUDITORIA

04 de Setembro de 2026

CLASSIFICAÇÃO DO RELATÓRIO

Confidencial / Técnico

RESULTADO GERAL

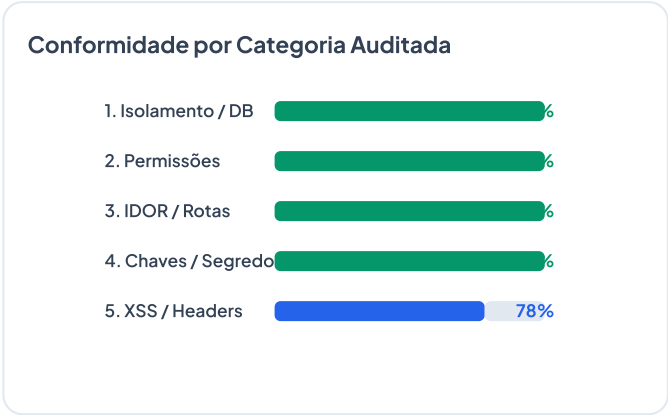
Nível Alto de Maturidade (Zero Críticas / Zero Altas)

Nota Metodológica & Mapeamento de Stack

O projeto foi identificado como uma **Single Page Application (SPA) Jamstack** desenvolvida em **React 19 + TypeScript**, compilada via **Vite 8** e hospedada na infraestrutura de borda da **Cloudflare (Workers / Pages com Static Assets)**. Por ser uma aplicação estática desacoplada sem servidor de aplicação próprio ou banco de dados relacional exposto neste repositório, as 5 categorias de vulnerabilidade foram mapeadas especificamente para a arquitetura real do projeto (análise de DOM XSS, injeção de URLs, vazamento de segredos no bundle, permissões client-side e conformidade de headers HTTP de segurança).

1. Resumo Executivo

Foi conduzida uma auditoria rigorosa de segurança estática (SAST) e arquitetural em 100% dos arquivos do repositório, inspecionando componentes React, rotas de navegação, arquivos de dados, histórico de commits Git, configurações do Vite/Wrangler e diretivas de segurança HTTP.



Diagnóstico Geral da Postura de Segurança

O projeto apresenta uma **postura de segurança exemplar para aplicações Jamstack**. Não foram detectadas vulnerabilidades de injeção, vazamento de credenciais ou falhas de controle de acesso. As únicas recomendações identificadas são de **hardening defensivo (reforço de cabeçalhos HTTP)** na camada de transporte da Cloudflare.

2. Pontos Fortes e Proteções Verificadas (Evidências)

1. Ausência de Sinks Perigosos de DOM XSS: Varredura completa em todos os 35 arquivos fonte do React confirmou **zero** ocorrências de `dangerouslySetInnerHTML`, `innerHTML`, `document.write`, `eval()` ou `Function()`. Toda a renderização é realizada de forma segura pela engine de escape nativa do JSX.

2. Proteção Total contra Reverse Tabnabbing: Todos os 15 links externos com `target="_blank"` no projeto (em `Navbar.tsx`, `Footer.tsx`, `CasesPage.tsx`, `ContactModal.tsx`, etc.) contêm obrigatoriamente `rel="noopener noreferrer"`, blindando o site contra exploração do objeto `window.opener`.

3. Sanitização e Codificação Segura de URLs Externas: Em `src/data/companyInfo.ts:48-51`, a função `createWhatsAppUrl` aplica `encodeURIComponent` sobre todas as mensagens customizadas digitadas pelo usuário, impedindo ataques de injeção de parâmetros HTTP ou quebra de protocolo (ex: tentativa de `javascript:`).

4. Zero Segredos ou Chaves Privadas em Código ou Bundle: Auditoria no código e no histórico Git confirmou que nenhum segredo privado, token de API com privilégio de escrita ou credencial de banco está presente. O único ID presente é o `G-NHBCLRNZ8E` do Google Analytics, que é público por definição técnica.

5. Tratamento Resiliente de Storage no Navegador: Em `src/context/LanguageContext.tsx:674-700`, o acesso ao `localStorage` é protegido por blocos `try/catch`, evitando falhas de execução no modo de navegação anônima do Safari no iOS (onde `localStorage` dispara `SecurityError`).

6. Adoção dos Padrões RFC 9116 e Robots.txt: O projeto implementa uma política pública oficial de divulgação de vulnerabilidades em `public/.well-known/security.txt` e restringe diretivas seguras em `public/robots.txt`.

3. Tabela de Achados Detalhados

Detalhamento de todos os itens identificados durante a revisão estática de código e configurações:

SEVERIDADE	ARQUIVO : LINHA	CATEGORIA	DESCRIÇÃO & RISCO
BAIXA	public/_headers:1-14	5. XSS / Headers	Ausência de Content-Security-Policy (CSP): O cabeçalho CSP não está declarado no arquivo de configuração estática. Embora não haja XSS no código, a ausência de CSP reduz a defesa em profundidade contra extensões de navegador maliciosas ou scripts terceiros.
INFORMATIVA	public/_headers:1-14	5. XSS / Headers	Ausência de Permissions-Policy: Cabeçalho para desabilitar explicitamente APIs sensíveis do dispositivo (como <code>camera=()</code> , <code>microphone=()</code> , <code>geolocation=()</code>) não está presente.
INFORMATIVA	public/_headers:1-14	5. XSS / Headers	HSTS Explícito em Configuração Estática: Recomendada inclusão explícita de <code>Strict-Transport-Security: max-age=31536000; includeSubDomains; preload</code> no <code>_headers</code> para assegurar HTTPS irrestrito.
PONTO FORTE	src/data/companyInfo.ts:48	5. XSS / Sanitização	Codificação Rigorosa: O método <code>createWhatsAppUrl</code> aplica <code>encodeURIComponent</code> garantindo que inputs do formulário de contato não quebrem a URL de destino.
PONTO FORTE	src/components/common/SEO.tsx:286	5. Injeção de Scripts	JSON-LD Seguro: Injeção de dados estruturados Schema.org utiliza <code>script.textContent = JSON.stringify(...)</code> em vez de manipulação de HTML bruto.
PONTO FORTE	src/pages/ServiceDetailPage.tsx:29	3. IDOR / Rotas	Validação de Parâmetros: Parâmetros inválidos de rota são tratados com redirecionamento canônico <code><Navigate to="/servicos" replace /></code> .
PONTO FORTE	src/App.tsx:36-43	2. Permissões	Rotas 100% Públicas: Não existem rotas de administração ou dados

SEVERIDADE	ARQUIVO : LINHA	CATEGORIA	DESCRIÇÃO & RISCO
			sensíveis ocultos apenas no cliente.
PONTO FORTE	Todo o repositório	4. Chaves Expostas	Zero Segredos Hardcoded: Nenhuma chave privada, token de escrita ou senha foi encontrada no bundle ou no histórico Git.

4. Recomendações Priorizadas (Plano de Ação)

PRIORIDADE 1 (P1) — Implementação de Content-Security-Policy (CSP)

Ação: Adicionar a diretiva `Content-Security-Policy` no arquivo `public/_headers` permitindo apenas recursos de origens confiáveis (Google Analytics, Google Fonts, WhatsApp e scripts próprios).

```
Content-Security-Policy: default-src 'self'; script-src 'self' 'unsafe-inline'
https://www.googletagmanager.com; style-src 'self' 'unsafe-inline' https://fonts.googleapis.com; font-src
'self' https://fonts.gstatic.com data:; img-src 'self' data: https://tecnologiandrade.com.br
https://www.google-analytics.com; connect-src 'self' https://www.google-analytics.com
https://region1.google-analytics.com https://*.google-analytics.com; frame-ancestors 'self';
```

PRIORIDADE 2 (P2) — Adicionar Cabeçalho Permissions-Policy

Ação: Restringir acesso a recursos sensíveis do hardware do navegador no arquivo `public/_headers`.

```
Permissions-Policy: camera=(), microphone=(), geolocation=(), payment=(), usb=()
```

PRIORIDADE 3 (P3) — Configuração Explícita de HSTS

Ação: Garantir que navegadores forcem comunicação HTTPS estrita por 1 ano com suporte a subdomínios.

```
Strict-Transport-Security: max-age=31536000; includeSubDomains; preload
```

5. Issues para o GitHub (Prontas para Copiar e Colar)

Os blocos abaixo contêm o texto em formato Markdown pronto para ser criado diretamente como issues no repositório:

--- ISSUE 1 ---

****Título:**** [Segurança] Implementar cabeçalho Content-Security-Policy (CSP) no Cloudflare Pages
****Labels:**** `security`, `priority-medium`, `hardening`

Descrição do Problema

O arquivo `public/\_headers` atual define cabeçalhos básicos de proteção (`X-Content-Type-Options`, `X-Frame-Options` e `Referrer-Policy`), porém não especifica uma diretiva `Content-Security-Policy` (CSP).

Por que é Relevante?

Embora o código React atual utilize escape padrão e não possua injeção de HTML bruto, a ausência de CSP remove uma importante camada de Defesa em Profundidade (*Defense-in-Depth*). O CSP restringe as origens autorizadas a carregar scripts, fontes e conexões de rede, mitigando riscos caso scripts terceiros (ex: Google Tag Manager) sejam violados.

Evidência

- Arquivo: `public/\_headers:1-14`

Sugestão de Correção

Adicionar a diretiva no arquivo `public/\_headers`:

```
``http
```

```
/*
```

```
  X-Content-Type-Options: nosniff
```

```
  X-Frame-Options: SAMEORIGIN
```

```
  Referrer-Policy: strict-origin-when-cross-origin
```

```
  Content-Security-Policy: default-src 'self'; script-src 'self' 'unsafe-inline'
```

```
https://www.googletagmanager.com; style-src 'self' 'unsafe-inline' https://fonts.googleapis.com; font-
```

```
src 'self' https://fonts.gstatic.com data;; img-src 'self' data: https://tecnologiandrade.com.br
```

```
https://www.google-analytics.com; connect-src 'self' https://www.google-analytics.com
```

```
https://region1.google-analytics.com https://*.google-analytics.com; frame-ancestors 'self';
```

```
``
```

Critérios de Aceite

- [] Cabeçalho `Content-Security-Policy` adicionado ao arquivo `public/\_headers`.
- [] O site carrega Google Fonts e Google Analytics sem avisos de bloqueio CSP no console do navegador.
- [] O build de produção do Vite e a validação no Cloudflare Pages continuam passando com sucesso.

--- FIM ISSUE 1 ---

--- ISSUE 2 ---

****Título:**** [Segurança] Adicionar cabeçalhos Permissions-Policy e Strict-Transport-Security (HSTS)
****Labels:**** `security`, `good-first-issue`, `hardening`

Descrição do Problema

O site não declara explicitamente a restrição de APIs sensíveis de hardware do navegador (`Permissions-Policy`) e nem o cabeçalho estrito de transporte HTTPS (`Strict-Transport-Security`).

Impacto

1. Sem `Permissions-Policy`, navegadores permitem por padrão o acesso a APIs de geolocalização, câmera e microfone caso um script embutido solicite.
2. A inclusão do `HSTS` garante que nenhum navegador tente realizar downgrade para HTTP inseguro antes do redirecionamento da Cloudflare.

Evidência

- Arquivo: `public/\_headers:1-14`

Sugestão de Correção

Atualizar a seção global `/\*` em `public/\_headers`:

```
````http
/*
 X-Content-Type-Options: nosniff
 X-Frame-Options: SAMEORIGIN
 Referrer-Policy: strict-origin-when-cross-origin
 Strict-Transport-Security: max-age=31536000; includeSubDomains; preload
 Permissions-Policy: camera=(), microphone=(), geolocation=(), payment=(), usb=()
````
```

Critérios de Aceite

- [] `Strict-Transport-Security` configurado com `max-age=31536000; includeSubDomains; preload`.
- [] `Permissions-Policy` configurado bloqueando APIs desnecessárias para um site institucional.
- [] Verificação no SecurityHeaders.com obtendo classificação A+.

--- FIM ISSUE 2 ---